Практическое задание №5
Встраивание инструментов динамического тестирования безопасности (DAST) в конвейер CI/CD в GitLab и GitHub

Задание

Ознакомьтесь с документацией инструмента динамического тестирования безопасности приложений (DAST – Dynamic Application Security Testing), в частности с разделом, описывающим использование Docker-образов и выполнение базового сканирования и сканирования REST API.

Для выполнения сканирования DAST, необходимо развернуть приложение. В учебных целях достаточно будет развернуть его на агенте GitLab/GitHub при выполнении работы сканирования перед непосредственным запуском сканирования.

Для того чтобы запустить процесс в фоновом режиме, после команды запуска приложения (`java -jar <путь к jar-файлу>`) необходимо в конце добавить символ `&`.

После запуска необходимо добавить команду `sleep`, чтобы дождаться запуска приложения.

Сканирование приложения нужно выполнить с помощью `zap-baseline.py` и `zap-api-scan.py`.

Настройка конвейера GitLab CI/CD

При использовании в работе Docker-образа можно указать не только его имя, но и переопределить точку входа:

```
image:
  name: ubuntu:latest
  entrypoint: [""]
```

В конвейер GitLab CI/CD:

1) на этапе `test` добавьте работу для динамического тестирования безопасности приложения с помощью OWASP Zap:

a. используйте Docker-образ `zaproxy/zap-stable`;
b. переопределите точку входа на пустую строку;
c. в качестве зависимостей укажите работы, которые требуется выполнить до запуска динамического тестирования приложения (например, сборка приложения);
d. подготовьте файл с правилами ZAP (в нашем случае подойдёт пустой файл в формате `tsv`);
e. запустите приложение в фоновом режиме;
f. добавьте ожидания запуска приложения (примерно 20-30 секунд)
g. запустите базовое сканирования с помощью `zap-baseline.py`;

2) добавьте аналогичную работу для динамического тестирования безопасности приложения (REST API) с помощью OWASP Zap (используйте `zap-api-scan.py`).
3) сохраните отчёты в виде артефактов (`artifacts:paths`).

Настройка рабочего процесса GitHub Actions

Ознакомьтесь с документацией по запуску базового сканирования и сканирования REST API с помощью GitHub Actions.

В рабочий процесс GitHub Actions:

1) добавьте работу для динамического тестирования безопасности приложения с помощью OWASP Zap с использованием базового сканирования:
   a. в качестве зависимостей укажите работы, которые требуется выполнить до запуска динамического тестирования приложения (например, сборка приложения);
   b. загрузите с помощью `actions/download-artifact@v4` собранный ранее артефакт (jar-архив);

c. подготовьте файл с правилами ZAP (в нашем случае подойдёт пустой файл в формате `tsv`);
d. запустите приложение в фоновом режиме;
e. добавьте ожидания запуска приложения (примерно 20-30 секунд)
f. воспользуйтесь `zaproxy/action-baseline@v0.9.0` для запуска базового сканирования.

2) добавьте аналогичную работу для динамического тестирования безопасности приложения (сканирование REST API) с помощью OWASP Zap (используйте `zaproxy/action-api-scan@v0.10.0`).
3) сохраните отчёты в артефакты с помощью `actions/upload-artifact@v4`.

Анализ результатов

1) Проанализируйте полученный отчёт.
2) Обновите отчёт, сделанный в практическом задании №4: дополните список реальных уязвимостей и список ложных срабатываний.
3) Предложите вариант устранения найденных уязвимостей.

Результат выполнения работы

– В сервисе GitLab создан Merge Request, изменяющий описание конвейера сборки.
– Конвейер включает работу на этапе test для динамического тестирования безопасности приложения (DAST) с помощью инструмента OWASP ZAP – базовое сканирование.
– Конвейер включает работу на этапе test для динамического тестирования безопасности приложения (DAST) с помощью инструмента OWASP ZAP – сканирование REST API.

- При любом завершении работы загружаются отчёты о проведении DAST в виде артефакта сборки.
- В сервисе GitHub создан Pull Request, изменяющий описание рабочего процесса.
- В рабочем процессе определена работа, выполняющая динамическое тестирование безопасности приложений (DAST) с помощью инструмента OWASP ZAP – базовое сканирование.
- В рабочем процессе определена работа, выполняющая динамическое тестирование безопасности приложений (DAST) с помощью инструмента OWASP ZAP – сканирование REST API.
- При любом завершении работы загружаются отчёты о проведении DAST в виде артефактов сборки.
- Дополнен список реальных уязвимостей.
- Дополнен список ложных срабатываний.
- Предложены варианты устранения уязвимостей.